

CS-1005-SEG

Intro a la Seguridad Computacional

6 de mayo de 2026

Agenda

- 1 Contexto y objetivos
- 2 **Lab 1.** Banco. JWT sin verificación de firma
- 3 **Lab 2.** Foro. Cracking de hashes MD5
- 4 **Lab 3.** Tickets. Desbordamiento de buffer
- 5 Cierre y discusión

Como trabajaremos cada lab

- 1 Introduccion al concepto tecnico.
- 2 Material de referencia (URL, credenciales, indicaciones).
- 3 Tiempo de trabajo individual.
- 4 Solucion comentada y conclusiones.

Lab 1

JSON Web Tokens

JWT: definicion

- Estandar abierto (RFC 7519) para transportar claims firmados.
- Tres segmentos separados por puntos:

`header . payload . signature`

■

`eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXLTUzODkwLjM1UkFsIDRnFmyG3nM`

- Vive en las cookies de tu PC.
- Uso tipico: sesiones, autorizacion entre microservicios.

JWT: estructura

Como funciona usualmente:

```
(1) HEADER: { "alg": "HS256", "typ": "JWT" }
```

```
>> JhbGci3Oi1IxMIxM
```

```
(2) PAYLOAD: { "user": "jorge", "type": "profe", "admin": false }
```

```
>> eyi0iIxm0iIxmMONTY30Dkw
```

```
(3) SIGNATURE: HMAC_SHA256( base64(header) + base64(payload), secret )
```

```
>> KMUFsIDTnFmyG3nM
```

JWT:

```
(1).(2).(3)
```

```
JhbGci3Oi1IxMIxM.eyJ0iIxm0iIxmMONTY30Dkw.KMUFsIDTnFmyG3nM
```

- El **payload** es legible por cualquiera: solo Base64.
- La **firma** es la unica garantia de integridad.

JWT: el error comun

Vulnerabilidad

El servidor decodifica el payload (JhbGci.3Oi1lx.MlxM – > user: Jorge) pero **no valida la firma.**

Consecuencia: cualquier cliente puede modificar el payload (admin, sub, expiracion) y ser aceptado.

- CWE-347, Improper Verification of Cryptographic Signature.
- Frecuente en bibliotecas mal configuradas y en SDKs propios.

Lab 1: Banco de Pangui

[Sucursales](#) [Cajeros automáticos](#) [Tarifas y tasas](#) [Atención al cliente](#) [Indicadores económicos](#) [Trabaja con nosotros](#) [Sostenibilidad](#)

 **Banco de Pangui**
BANCA EN LÍNEA

¿Qué estás buscando?

[Personas](#) [Pyme y Empresas](#) [Empresas](#) [Banca Privada](#) [Inversiones](#) [Internacional](#)

Su banco de confianza, ahora en línea.

Realice sus transferencias, pagos e inversiones desde cualquier dispositivo, con la seguridad y respaldo que nos caracteriza desde 1893.

[✓ Transferencias inmediatas](#) [✓ Inversión en línea](#) [✓ Sucursal virtual 24/7](#) [✓ Soporte permanente](#)

Banca en Línea **Empresas**

Ingreso clientes
Acceda con su RUT y clave secreta

RUT
12.345.678-9

CLAVE DE ACCESO

 Su sesión está protegida con cifrado TLS 1.3.

INGRESAR

[¿Olvidó su clave?](#) [Primer ingreso](#)

 Verifique siempre la dirección antes de ingresar sus datos.

 **Cuenta corriente**
Solicite la suya en línea

 **Tarjetas**
Crédito y débito

 **Inversiones**
Fondos mutuos y DAP

 **Hipotecario**
Cotice su crédito

PRODUCTOS
[Cuentas](#)

ATENCIÓN
[Sucursales](#)

SOBRE EL BANCO
[Quiénes somos](#)

SEGURIDAD
[Recomendaciones](#)

Lab 1: Material de referencia

Acceso

COMMAND	bank
RUT	12.345.678-9
Clave	banco2025

- Objetivo: acceder al panel administrativo y recuperar los fondos.
- **Clippy** disponible en todo momento con pistas progresivas.

Lab 1: Solucion y conclusiones

Pasos del exploit

- 1 Login normal; capturar `session_token` en `localStorage`.
- 2 Decodificar en `jwt.io`; cambiar `admin: false` a `true`.
- 3 `localStorage.setItem('session_token', ...)` y recargar.

- Nunca confiar en JWT claims sin verificar la firma.
- Validar tambien `alg`: rechazar `none` y mezclas HS/RS.
- Rotar secretos; usar bibliotecas auditadas (`jose`, `pyjwt`).

Lab 2

Hashes MD5 y filtraciones

Funciones hash: recordatorio

- Una funcion hash mapea entradas arbitrarias a salidas de tamaño fijo.
- Propiedades: resistencia a preimagen (tengo hash, conseguir clave), colisiones.
- Uso comun: almacenamiento de contraseñas, integridad de archivos.

```
password = "password123"  
  
md5(password)  
>> e63a2b4c2e1d3c2e1d31ceba
```

MD5: por que esta roto

- Diseno de 1991; salida de 128 bits.
- Colisiones practicas demostradas desde 2004 (Wang et al.).
- Calculable en miles de millones de hashes/seg en GPU moderna.
- Las contraseñas comunes son recuperables con tablas publicas.
- "123456" es una contraseña muy comun. Busco online si alguien ya calculo el hash. Ahora puedo revertir.

Lab 2: ForoUnder

[Inicio](#) [Reglas](#) [Tor minor](#) [Crypto](#) 2.847 conectados

 **ForoUnder**
EL FORO LIBRE DE LA RED

Q Buscar en filtraciones, hilos, usuarios...

Mensajes (3) [anon_estudiante](#)

[Inicio](#) [Filtraciones](#) 412 [Hacking](#) 1.8K [Anonimato](#) [Crypto](#) [Mercado](#) [Off-topic](#)

[Inicio](#) > [Filtraciones](#) > [Gobierno y banca](#) > [FILTRACIÓN] Acceso completo a ClaveÚnica — 47K usuarios

[FILTRACIÓN](#) [ESTATAL](#) [HOT](#) [✓ VERIFICADO POR STAFF](#)

[DUMP] Acceso completo a base de datos de ClaveÚnica — 47.892 usuarios + hashes

[jmun_h4ck3r](#) [publicado hace 6 horas](#) [14.231 visitas](#) [87 respuestas](#)


jmun_h4ck3r
• ELITE


Reputación +2.418

Mensajes 1.247

Filtraciones 34

Registrado ene 2022

País 

Publicado 2025-04-30 03:14:09 #1

Qué pasa chavales. Después de tres meses, hoy dropeo lo que les prometí: **acceso completo a la base de ClaveÚnica**. Cuarenta y siete mil ochocientos noventa y dos cuentas, todas con su RUT, email y hash de clave. El endpoint de ClaveÚnica tenía un endpoint expuesto sin rate-limit y yo aprendí en la clase que eso es un problema.

Lo más entretenido es lo que viene después. El **Servicio de Impuestos Injustos** (sí, los mismos que te quitan medio sueldo) confía en ClaveÚnica para todo: renta, F22, boletas, libro de remuneraciones, todo. Si tienes la clave de un usuario, eres ese usuario para el SII.

Alguien sabe si se pueden hackear los hashes para tener las claves?

cu_dump_sample.txt 12 filas · MD5 · sin salt

ID	RUT	EMAIL	PASSMORD_MD
00001	6.482.131-9	jose.contreras@a11.cl	a47f9d22c6

HILOS

[Banco de Pangul — JWT vulnerable](#)
1.412 · hace 2 d

[\[ESTÁS AQUÍ\] ClaveÚnica — 47K dump](#)
1.2418 · hace 6 h

REGLAS DEL SUBFORO

- No doxxing de personas naturales.
- Solo dumps de entidades, no de individuos privados.
- Verificación obligatoria por staff antes de pinrear.
- El que vende, fuera. Aquí se libera.
- OPSEC propia. No nos hacemos cargo.

Lab 2: Material de referencia

Acceso

COMMAND	forum
INFO	leak.txt (descargable desde el foro)
LOGIN	Buscar link en el foro

- Intenta loggearte al SII usando la info del foro.
- **Clippy** siempre te puede ayudar!

Lab 2: Solucion y conclusiones

Pasos del exploit

- 1 Descargar leak.txt desde el hilo del foro.
 - 2 Probar cada hash en una rainbow table publica.
 - 3 Hash reversible: 482c811d... → password123.
 - 4 Iniciar sesion en ClaveUnica con ese RUN
-
- MD5 sin sal equivale a contrasenas en texto plano.
 - Reutilizacion de credenciales amplifica el dano de un solo dump.

Lab 3

Desbordamiento de buffer en pila

Stack buffer overflow

- Escritura mas alla del tamaño declarado de una lista en el stack.
- Sobrescribe variables vecinas, punteros y la dirección de retorno.
- Origen histórico: lenguajes sin verificación de límites (C/C++) (Python sobrevive).

El handler vulnerable

```
def register(username, password):  
    username_buffer = [0, 0, 0, 0, 0, 0, 0, 0]  
    password_buffer = [0, 0, 0, 0, 0, 0, 0, 0]  
  
    for i, c in enumerate(username):  
        username_buffer[i] = c  
  
    for i, c in enumerate(password):  
        password_buffer[i] = c  
  
    is_admin = False  
  
    return User(username_buffer, password_buffer, is_admin)
```

Escribir mas de 8 bytes desborda hacia is_admin y price.

Defensas clasicas

Buenas practicas

- Bounds checking explicito.
- Stack canaries (`-fstack-protector`).
- Lenguajes con seguridad de memoria (Python).

Gusanos historicos: Morris (1988), Code Red (2001), Slammer (2003).

Lab 3: Final del Mundial 2026

The screenshot shows the official ticket portal for the 2026 World Cup Final. The header includes navigation links for Tournament, Teams, News, and Help, along with a 'SALES WINDOW: CLOSING SOON' alert. The main content area features the match title 'THE FINAL.' with the flags of Chile and España (Spain) separated by a 'VS' icon. Below this, the date and time '19 JUL 2026 · 20:00 LOCAL' are displayed, along with a 'WORLDWIDE BROADCAST' icon. A large countdown timer shows 74 days, 01 hour, 23 minutes, and 03 seconds remaining. At the bottom, the 'FINAL · CHI VS ESP · AVAILABLE CATEGORIES' section includes a note about demand and a 'YOUR WALLET \$500.00' indicator, with a 'HIGH DEMAND · 1.2M IN QUEUE' warning.

Tournament Teams News Help

26 WORLD CUP 26
OFFICIAL TICKET PORTAL

Tickets Schedule Teams Account EN · ES · PT

• KNOCKOUT · FINAL MATCH · 19 JULY 2026

THE FINAL.

CHILE VS ESPAÑA

19 JUL 2026 · 20:00 LOCAL WORLDWIDE BROADCAST

74 01 23 03
DAYS HOURS MIN SEC

FINAL · CHI VS ESP · AVAILABLE CATEGORIES

Demand has reached unprecedented levels. Resale prices reflect official secondary market.

YOUR WALLET \$500.00

• HIGH DEMAND · 1.2M IN QUEUE

Lab 3: Material de referencia

Acceso

COMMAND final

- Componer el payload en la bandeja y presionar **EXECUTE**.
- Campo custom... acepta texto libre, podemos hacer un overflow?.
- **Clippy** te ayuda antes, durante y despues del exploit.

Lab 3: Solucion y conclusiones

Soluciones

- $\text{SUMMER25} + 9999 \Rightarrow \text{price} = 0?$.
 - $A \times 8 + 9999 \Rightarrow \text{price} = 0?$.
 - $A \times 8 + \text{XD} \Rightarrow \text{price} = -1302314$.
-
- Una variable adyacente al buffer puede ser tan critica como un puntero.
 - Los exploits de memoria siguen vigentes: kernel, navegadores, IoT.

CS-1005-SEG

Intro a la Seguridad Computacional

6 de mayo de 2026